

STATEMENT OF OBJECTIVES

National Student Clearinghouse (NSC) Enrollment Verification Services

1.0 Purpose

The Centers for Medicare & Medicaid Services (CMS) seeks to obtain access to authoritative educational enrollment verification data through the National Student Clearinghouse (NSC) to support Medicaid eligibility and program compliance verification.

The purpose of this Statement of Objectives (SOO) is to describe the expected outcomes for integrating NSC enrollment verification services into CMS API-based ecosystem supporting health and human services eligibility workflows. This integration will enable state benefit agencies to securely verify education participation status for applicants and beneficiaries.

This effort supports CMS's obligations under federal eligibility verification requirements, including those established under 42 CFR Part 435, Subpart J. It also directly supports CMS's preparedness for community engagement requirements established under the One Big Beautiful Bill Act (HR1), which takes effect January 2027. Under HR1, certain Medicaid beneficiaries must verify participation in qualifying activities — including educational enrollment — as a condition of eligibility. NSC enrollment verification is a primary data source for satisfying this requirement at scale.

This integration will support state Medicaid and other health and human services agencies by:

- Improving the efficiency and accuracy of eligibility determinations
- Reducing the reporting burden on beneficiaries
- Providing states with streamlined access to authoritative enrollment verification data
- Reducing duplicative integrations and costs across states
- Enabling timely readiness for HR1 community engagement verification requirements effective January 2027

2.0 Background

CMS, through the Center for Medicaid and CHIP Services (CMCS) – the CMS component responsible for Medicaid and CHIP policy and operations – has several platforms to support Medicaid and other health and human services eligibility verification and program compliance workflows through trusted third-party data sources.

The NSC maintains one of the most comprehensive repositories of postsecondary enrollment data in the United States, representing thousands of educational institutions. By integrating NSC verification services into CMS platforms, CMS intends to provide participating state agencies with a standardized, centralized mechanism to verify educational enrollment status.

The urgency of this integration is reinforced by HR1, which establishes community engagement requirements for certain Medicaid beneficiaries effective January 2027. Educational enrollment is an explicitly qualifying activity under these requirements. States will need reliable, scalable access to enrollment verification data to implement HR1 compliance workflows. The NSC integration is designed to provide that capability ahead of the statutory deadline.

3.0 Current Environment

State Medicaid agencies operate eligibility systems that require verification of applicant-provided information. The current landscape presents significant operational challenges across many of the states and territories served by Medicaid.

Verification processes currently involve manual submission of documentation, caseworker verification activities, and inconsistent access to authoritative datasets. These approaches result in increased administrative burden on beneficiaries, processing delays, and inconsistent verification practices across states.

These challenges will be significantly compounded by HR1's community engagement requirements. Beginning January 2027, states must verify qualifying activity participation — including education — for a substantially larger population of Medicaid beneficiaries. Manual and fragmented verification approaches are not scalable to meet this demand.

CMS is providing multiple API services to address these pain points by enabling states to access trusted verification sources through a standardized API-based service — reducing burden, improving consistency, and lowering costs at scale in advance of the HR1 implementation deadline.

4.0 Scope

CMS requires services from the NSC to provide educational enrollment verification data accessible through CMS API platform. The current scope includes high school, high school equivalent programs, and postsecondary enrollment verification for individuals applying for or receiving Medicaid and other health and human services benefits, including verification required under HR1 community engagement provisions.

The scope includes:

- Enabling verification of high school, high school equivalent programs, and postsecondary enrollment status
- Supporting secure data exchange with CMS API enabled platforms
- Providing relevant enrollment attributes necessary to support eligibility determinations and HR1 community engagement compliance workflows

Out of Scope: This effort does not include verification of enrollment at international institutions not participating in NSC data sharing..

Future Extensibility: CMS is expecting future expansion to additional federal benefit programs. The Contractor should be aware of this potential and ensure that integration design does not preclude future extensibility to other programs or agencies.

4.1 Period and Place of Performance

The anticipated period of performance includes a base period of [X months/years] with up to [X] option periods. Given the HR1 effective date of January 2027, CMS prioritizes integration readiness no later than June 1, 2026[target date]. Work will primarily involve technical coordination and data exchange between CMS technical teams and the NSC. No physical place of performance is required; all work is expected to be conducted remotely through secure electronic means.

4.2 Deliverables

Deliverable Name	Due Date / Frequency	Format
API Access / Integration Documentation	Within 30 days of contract award	Digital
Integration Support Materials	As required	Digital

Testing Environments with Relevant Test Data, Mimicking Production Data	Within 30 days of contract award	Digital
Status Reports	Periodic (frequency TBD)	Digital
Technical Briefings	As requested	Presentation
Monthly Usage Reports (by State and Overall)	Monthly	Digital
Weekly Usage Reports	Weekly	Digital
Monthly Financial Reports	Monthly	Digital
Availability for Troubleshooting (State-Specific or System-Wide)	As needed, with minimal advance notice	Ongoing / On-Demand

Descriptive Language to Accompany the Table

- **API Access / Integration Documentation:** The Contractor shall provide complete API access and integration documentation within 30 days of contract award. Documentation shall include all technical specifications, authentication requirements, and data exchange formats necessary for CMS and participating states to integrate with NSC verification services.
- **Integration Support Materials:** The Contractor shall provide integration support materials as required throughout the period of performance. These materials shall support CMS technical teams and participating states in implementing and maintaining the NSC verification integration.
- **Status Reports:** The Contractor shall provide periodic status reports (frequency to be determined during the acquisition process) summarizing progress, issues, and upcoming activities related to the NSC-CMS integration.
- **Technical Briefings:** The Contractor shall be available to provide technical briefings as requested by CMS. Briefings shall address integration status, technical issues, and any updates to NSC systems or data that may affect CMS platform operations.
- **Monthly Usage Reports:** The Contractor shall provide monthly reports detailing verification transaction volumes, disaggregated by participating state and in aggregate. Reports shall include sufficient detail to support program oversight, cost allocation, and state-level billing if applicable.
- **Weekly Usage Reports:** The Contractor shall provide weekly usage reports summarizing transaction volumes and any anomalies or errors encountered during the reporting period. These reports are intended to support rapid identification of the onset of technical issues or data discrepancies.
- **Monthly Financial Reports:** The Contractor shall provide monthly financial reports documenting usage-based costs by state and in aggregate. These reports are a prerequisite for any future state-specific billing arrangements and shall be provided in a format compatible with CMS financial management requirements.

- **Availability for Troubleshooting:** The Contractor shall be available to support troubleshooting of state-specific or system-wide issues with minimal advance notice. The Contractor shall designate a technical point of contact responsible for responding to CMS and state-reported issues in a timely manner, consistent with the SLAs defined in Section 8.0 below.

Acceptance criteria for all deliverables will be defined during the acquisition process and incorporated into the resulting contract.

5.0 Performance Objectives

Objective 1: Provide Educational Enrollment Verification Data

The Contractor shall provide access to authoritative educational enrollment data maintained by the NSC. The data shall support verification of an individual's current or recent enrollment status at high school, high school equivalent programs, or postsecondary educational institutions participating in NSC data sharing, including for purposes of satisfying HR1 community engagement qualifying activity requirements.

Relevant data attributes may include, but not limited to:

- School Name
- Enrollment Status (e.g., full-time, three-quarter time, half-time, less than half-time, enrolled)
- Term Begin Date
- Term End Date
- Program Graduation Date
- Student Name on Institutional Record

Data provided shall be accurate, authoritative, and updated at a frequency sufficient to reflect current enrollment status — at minimum, updated once per academic term. Data quality and timeliness are essential to support reliable eligibility determinations and HR1 compliance verification.

Objective 2: Support Integration with the CMS API Platforms

The Contractor shall support integration with the CMS API platforms through secure API-based data exchange. Verification requests initiated by CMS through the CMS APIs may include the following attributes.

Data transmitted by CMS (illustrative):

- First Name
- Last Name
- Date of Birth
- Verification As-of Date
- Account Identifier
- Client Identifier
- Consent / Terms Flag

Data returned by the Contractor (illustrative):

- Verified Enrollment Status
- Educational Institution Name
- Educational Institution Address (including City and State)
- Academic Term Dates
- Program Graduation Date
- Student Name on Record

This exchange is illustrative and not intended to limit potential implementation approaches.

Objective 3: Support Consent-Based Verification

The Contractor shall support verification workflows in which individuals authorize CMS or participating state Medicaid agencies to request verification of their educational enrollment information. The verification process shall respect applicable privacy protections and consent requirements, including those established under the Family Educational Rights and Privacy Act (FERPA), which governs the privacy of student education records and conditions under which such records may be disclosed.

Objective 4: Support Cost-Effective Access for States

The Contractor shall provide pricing structures that allow CMS to negotiate centralized agreements and make enrollment verification services available to participating states through the CMS platforms. CMS intends to reduce the cost burden on individual states by enabling shared access to the verification service, eliminating the need for states to independently negotiate and maintain separate NSC agreements. This is particularly important given the increased verification volume anticipated under HR1 community engagement requirements beginning January 2027.

Objective 5: Enable Technical Interoperability and HR1 Readiness

The Contractor shall ensure that verification services are technically compatible with the CMS platforms API architecture and CMS integration standards. The Contractor shall support testing, onboarding, and ongoing technical coordination to ensure reliable and consistent service delivery across participating states.

Given the HR1 effective date of January 2027, the Contractor shall prioritize integration readiness activities to ensure that participating states can operationalize enrollment verification workflows in advance of the statutory deadline. This includes supporting any necessary testing, certification, or onboarding activities required for state readiness.

The Contractor shall also ensure that the integration architecture is designed with extensibility in mind. While the current scope is primarily focused on Medicaid, the CMS platforms may expand to support additional federal benefit programs in the future. Integration design should not create technical barriers to such expansion.

6.0 Constraints

Solutions must comply with applicable federal privacy, security, and education data requirements, including:

- Protection of personally identifiable information (PII) in accordance with the Privacy Act of 1974
 - Compliance with FERPA requirements governing the disclosure of student education records
 - Secure transmission of data using federally approved encryption standards
 - Appropriate authentication and authorization mechanisms
 - Compliance with federal cybersecurity standards, including NIST SP 800-53 security controls (e.g., Acceptable Risk Controls for ACA, Medicaid, and Partner Entities [ARC-AMPE] tailored controls for service providers), FISMA requirements, and FedRAMP authorization standards where applicable
 - Alignment with HR1 implementation guidance and any associated federal regulations governing community engagement verification workflows, as issued by CMS
-

7.0 Government Furnished Information (GFI)

CMS may provide the following to support contractor performance:

- EMMY API,CMS Hub API and other technical documentation, as needed
- Data exchange specifications
- Testing or sandbox environments
- Relevant policy guidance and integration standards
- HR1 implementation guidance and community engagement verification requirements as they are finalized

No Government Furnished Equipment (GFE) is anticipated.

8.0 Service Level Agreements (SLAs)

The Contractor shall meet the following minimum service level standards. These SLAs apply to all participating states accessing NSC enrollment verification services through CMS platforms. CMS reserves the right to refine or expand these SLAs during the acquisition process and incorporate final SLA terms into the resulting contract.

SLA Category	Metric	Target
System Availability / Uptime	NSC verification service availability	≥ 99.5% uptime, measured monthly

SLA Category	Metric	Target
Planned Maintenance Windows	Advance notice to CMS and states	Minimum 5 business days' notice
API Response Time	Time to return a verification response per request	≤ [X] seconds per transaction (TBD)
Incident Response – Critical (System-Wide Outage)	Time to acknowledge and begin remediation	Within 1 hour of notification
Incident Response – High (State-Specific Issue)	Time to acknowledge and provide initial response	Within 4 business hours of notification
Incident Response – Medium/Low	Time to acknowledge and provide initial response	Within 1 business day of notification
Issue Resolution	Time to resolve reported incidents	Per severity tier (TBD during acquisition)

SLA Category	Metric	Target
State Onboarding Support	Time to complete onboarding for a new participating state	Within [X] business days of request (TBD)
Data Freshness / Update Frequency	Enrollment data updated at minimum	Once per academic term
Reporting Delivery	Weekly and monthly reports delivered on time	100% on-time delivery

Additional SLA Notes:

- The Contractor shall maintain a ticketing or issue-tracking system accessible to CMS and participating states for logging, tracking, and resolving reported issues.
- The Contractor shall provide a designated technical point of contact and an escalation path for unresolved issues.
- SLA performance shall be reported in the Monthly Usage Reports and reviewed by CMS on a quarterly basis.
- Failure to meet SLA targets may result in remediation requirements or other contractual consequences as defined in the resulting contract.

Appendix A:

1. Baseline Security Requirements

- a. **Applicability.** The requirements herein apply whether the entire contract or modification (hereafter "contract"), or portion thereof, includes either or both of the following:
 - i. **Access (Physical or Logical) to Government Information:** A Contractor (and/or any subcontractor) will have or will be given the ability to have, routine physical (entry) or logical (electronic) access to government information.
 - ii. **Operate a Federal System Containing Information:** A Contractor (and/or any subcontractor) will operate a federal system and information technology containing data that supports the HHS mission. In addition to the Federal Acquisition Regulation (FAR) Subpart 2.1 definition of "information technology" (IT), the term as used in this section includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including support services), and related resources.
- b. **Safeguarding Information and Information Systems.** All government information and information systems must be protected in accordance with HHS/ CMS policies and level of risk. At a minimum, the Contractor (and/or any subcontractor) must:
 - i. Protect the:
 - **Confidentiality**, which means preserving authorized restrictions on access and disclosure, based on the security terms found in this contract, including means for protecting personal privacy and proprietary information;
 - **Integrity**, which means guarding against improper information modification or destruction, and ensuring information non-repudiation and authenticity; and
 - **Availability**, which means ensuring timely and reliable access to and use of information.
 - ii. Categorize all information owned and/or collected/managed on behalf of HHS/CMS and information systems that store, process, and/or transmit HHS information in accordance with FIPS 199 and National Institute of Standards and Technology ([NIST\) Special Publication \(SP\) 800-60, Volume II:](#)

[Appendices to Guide for Mapping Types of Information and Information Systems to Security Categories.](#)

Based on information provided by the ISSO, CISO, CMS SOP, or other representative, the impact level for each Security Objective (Confidentiality, Integrity, and Availability) and the Overall Impact Level, which is the highest watermark of the three factors of the information or information system are the following:

- **Confidentiality:** ☐ Low ☐ Moderate ☐ High
 - **Integrity:** ☐ Low ☐ Moderate ☐ High
 - **Availability:** ☐ Low ☐ Moderate ☐ High
 - **Overall Impact Level:** ☐ Low ☐ Moderate ☐ High
- iii. Based on the agreed-upon level of impact, implement the necessary safeguards to protect all information systems and information collected and/or managed on behalf of HHS/CMS regardless of location or purpose.
 - iv. Report any discovered or unanticipated threats or hazards by either the agency or contractor, or if existing safeguards have ceased to function immediately after discovery, **within one (1) hour or less**, to the government representative(s).
 - v. Adopt and implement all applicable policies, procedures, controls, and standards required by the HHS/CMS Information Security Program to ensure the confidentiality, integrity, and availability of government information and government information systems for which the Contractor is responsible under this contract or to which the Contractor may otherwise have access under this contract. Obtain all applicable security and privacy policies by contacting the CO/COR or HHS/CMS security and/or privacy officials.
- c. **Privacy Act.** Comply with the Privacy Act requirements (when applicable), and tailor FAR and HHSAR clauses as needed.
 - d. **Privacy Compliance.** Comply with the E-Government Act of 2002, NIST SP 800-53, and applicable HHS/CMS privacy policies, and complete all the requirements below:
 - i. Per the Office of Management and Budget (OMB) Circular A-130, Personally Identifiable Information (PII), is "information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual." Examples of PII include, but are not limited to the following: Social Security number, date and place of birth, mother's maiden name, biometric records, etc.

- ii. Based on information provided by the ISSO, system/data owner, or other security or privacy representative, it has been determined that this solicitation/contract involves:

[] No PII [] PII

- iii. The Contractor must support the agency with conducting a Privacy Threshold Analysis (PTA) for the information system and/or information handled under this contract to determine whether or not a full Privacy Impact Assessment (PIA) needs to be completed.

111

- If the results of the PTA show that a full PIA is needed, the Contractor must support the agency with completing a PIA for the system or information within *[CMS to insert contract-specific timeline]* after completion of the PTA and in accordance with HHS policy and OMB M-03-22, *Guidance for Implementing the Privacy Provisions of the E-Government Act of 2002*.
- The Contractor must support the agency in reviewing the PIA at least every **three years** throughout the system development lifecycle (SDLC)/information lifecycle, or when determined by the agency that a review is required based on a major change to the system, or when new types of PII are collected that introduces new or increased privacy risks, whichever comes first.

- e. **Controlled Unclassified Information (CUI). Executive Order 13556 defines** CUI as "information that laws, regulations, or Government-wide policies require to have safeguarding or dissemination controls, excluding classified information." The Contractor (and/or any subcontractor) must comply with *Executive Order 13556, Controlled Unclassified Information, (implemented at 3 CFR, part 2002)* when handling CUI. 32 C.F.R. 2002.4(aa) As implemented the term "*handling*" refers to "...any use of CUI, including but not limited to marking, safeguarding, transporting, disseminating, re-using, and disposing of the information." 81 Fed. Reg. 63323. The requirements below apply only to nonfederal systems that process, store, or transmit CUI, or that provide security protection for such components. All sensitive information that has been identified as CUI by a regulation or statute, handled by this solicitation/contract, must be:

- i. Marked appropriately;
- ii. Disclosed to authorized personnel on a Need-To-Know basis;
- iii. Protected in accordance with NIST SP 800-53, *Security and Privacy Controls for Information Systems and Organizations* applicable baseline if handled by a Contractor system operated on behalf of the agency, or NIST SP 800-171, *Protecting Controlled Unclassified Information in Nonfederal Information Systems and Organizations* if handled by internal Contractor system; and

- iv. Returned to HHS control, destroyed when no longer needed, or held until otherwise directed. Information and/or data must be disposed of in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*.
- f. **Protection of Sensitive Information.** For security purposes, information is or may be sensitive because it requires security to protect its confidentiality, integrity, and/or availability. The Contractor (and/or any subcontractor) must protect all government information that is or may be sensitive by securing it with a solution that is validated with current FIPS 140 validation certificate from the NIST CMVP.
- g. **Confidentiality and Nondisclosure of Information.** Any information provided to the contractor (and/or any subcontractor) by HHS or collected by the contractor on behalf of HHS must be used only for the purpose of carrying out the provisions of this contract and must not be disclosed or made known in any manner to any persons except as may be necessary in the performance of the contract. The Contractor assumes responsibility for protection of the confidentiality of Government records and must ensure that all work performed by its employees and subcontractors must be under the supervision of the Contractor. Each Contractor employee or any of its subcontractors to whom any HHS records may be made available or disclosed must be notified in writing by the Contractor that information disclosed to such employee or subcontractor can be used only for that purpose and to the extent authorized herein.

The confidentiality, integrity, and availability of such information must be protected in accordance with HHS and CMS policies. Unauthorized disclosure of information will be subject to the HHS/CMS sanction policies and/or governed by the following laws and regulations:

- i. 18 U.S.C. 641 (Criminal Code: Public Money, Property or Records);
- ii. 18 U.S.C. 1905 (Criminal Code: Disclosure of Confidential Information); and
- iii. 44 U.S.C. Chapter 35, Subchapter I (Paperwork Reduction Act).
- h. **Internet Protocol Version 6 (IPv6).** All procurements using Internet Protocol must comply with OMB Memorandum M-05-22, *Transition Planning for Internet Protocol Version 6 (IPv6)*.
- i. **Information and Communications Technology (ICT).** ICT products and services from prohibited entities/sources must not be used/acquired in compliance with Public Law 115-232, Section 889 Parts A and B, FAR 4.21, FAR 52.204.23, FAR 52.204.24, and FAR 52.204.25. The contractor (and/or any subcontractor) must notify the government if they identify prohibited ICT products and/or services are used during the contract performance.
- j. **Government Websites.** All new and existing public-facing government websites must be securely configured with Hypertext Transfer Protocol Secure (HTTPS) using the most recent version of Transport Layer Security

(TLS). In addition, HTTPS must enable HTTP Strict Transport Security (HSTS) to instruct compliant browsers to assume HTTPS at all times to reduce the number of insecure redirects and protect against attacks that attempt to downgrade connections to plain HTTP. For internal-facing websites, HTTPS is not required, but it is highly recommended. Consult the *HHS Policy for Internet and Email Security* for additional information.

- k. **Contract Documentation.** The Contractor must use provided templates, policies, forms and other agency documents found at <https://www.cms.gov/Research-Statistics-Data-and-Systems/CMS-Information-Technology/InformationSecurity/Information-Security-Library> to comply with contract deliverables as appropriate.

Standard for Encryption. The Contractor (and/or any subcontractor) must:

- i. Comply with the *HHS Standard for Encryption of Computing Devices and Information* to prevent unauthorized access to government information.
 - ii. Encrypt all sensitive federal data and information (i.e., PII, protected health information [PHI], proprietary information, etc.) in transit (i.e., email, network connections, etc.) and at rest (i.e., servers, storage devices, mobile devices, backup media, etc.) with encryption solution that is validated with current FIPS 140 validation certificate from the NIST CMVP.
 - iii. Secure all devices (i.e.: desktops, laptops, mobile devices, etc.) that store and process government information and ensure devices meet HHS and CMS-specific encryption standard requirements. Maintain a complete and current inventory of all laptop computers, desktop computers, and other mobile devices and portable media that store or process sensitive government information (including PII).
 - iv. Verify that the encryption solutions in use have been validated under the Cryptographic Module Validation Program to confirm compliance with current FIPS 140 validation certificate from the NIST CMVP. The Contractor must provide a written copy of the validation documentation to the COR [CMS-provided delivery date].
 - v. Use the Key Management system on the HHS personal identification verification (PIV) card or establish and use a key recovery mechanism to ensure the ability for authorized personnel to encrypt/decrypt information and recover encryption keys <http://csrc.nist.gov/publications/>. Encryption keys must be provided to the COR upon request and at the conclusion of the contract.
- l. **Contractor Non-Disclosure Agreement (NDA).** Each Contractor (and/or any subcontractor) employee having access to non-public government information under this contract must complete the CMS non-disclosure agreement. Contractors (and/or subcontractors) must submit a copy of each signed and witnessed NDA to

the Contracting Officer (CO) and/or CO Representative (COR) prior to performing any work under this acquisition.

2. Training Requirements

- a. **Mandatory Training for All Contractor Staff.** All Contractor (and/or any subcontractor) employees assigned to work on this contract must complete the applicable HHS/CMS Contractor Information Security Awareness, Privacy, and Records Management training (provided upon contract award) before performing any work under this contract. Thereafter, the employees must complete CMS Information Security Awareness, Privacy, and Records Management training at least **annually**, during the life of this contract. All provided training must be compliant with HHS training policies.
- b. **Role-based Training.** All Contractor (and/or any subcontractor) employees with significant security responsibilities (as determined by the program manager) must complete role-based training **annually** commensurate with their role and responsibilities in accordance with HHS policy and the *HHS Role-Based Training (RBT) of Personnel with Significant Security Responsibilities Memorandum*.
- c. **Training Records.** The Contractor (and/or any subcontractor) must maintain training records for all its employees working under this contract in accordance with HHS policy. A copy of the training records must be provided to the CO and/or COR within **30 days** after contract award and **annually** thereafter or upon request.

3. Rules of Behavior

- a. The Contractor (and/or any subcontractor) must ensure that all employees performing on the contract comply with the *HHS Information Technology General Rules of Behavior*, and *HHS Rules of Behavior for Privileged Users*.
- b. All Contractor employees performing on the contract must read and adhere to the Rules of Behavior before accessing Department data or other information, systems, and/or networks that store/process government information, initially at the beginning of the contract and at least **annually** thereafter, which may be done as part of annual CMS Information Security Awareness Training. If the training is provided by the contractor, the signed ROB must be provided as a separate deliverable to the CO and/or COR per defined timelines above.

4. Incident Response

- a. The Contractor (and/or any subcontractor) must respond to all alerts/Indicators of Compromise (IOCs) provided by HHS Computer Security Incident Response Center (CSIRC)/ CMS IRT teams **within 24**

hours, whether the response is positive or negative.

FISMA defines an incident as "an occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies. In accordance with OMB M-17-12, *Preparing for and Responding to a Breach of Personally Identifiable Information (PII)*, an incident is "an occurrence that (1) actually or imminently jeopardizes, without lawful authority, the integrity, confidentiality, or availability of information or an information system; or (2) constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies" and a privacy breach is "the loss of control, compromise, unauthorized disclosure, unauthorized acquisition, or any similar occurrence where (1) a person other than an authorized user accesses or potentially accesses personally identifiable information or (2) an authorized user accesses or potentially accesses personally identifiable information for an other than authorized purpose." For additional information on the HHS breach response process, please see the *HHS Policy and Plan for Preparing for and Responding to a Breach of Personally Identifiable Information (PII)*."

- b. In the event of a suspected or confirmed incident or breach, the Contractor (and/or any subcontractor) must:
 - i. Protect all sensitive information, including any PII created, stored, or transmitted in the performance of this contract, with encryption solution that is validated with current FIPS 140 validation certificate from the NIST CMVP.
 - ii. NOT notify affected individuals unless so instructed by the Contracting Officer or designated representative. If so instructed by the Contracting Officer or representative, the Contractor must send CMS approved notifications to affected individuals in accordance with the CMS Breach Analysis Team (BAT) instruction.
 - iii. Report all suspected and confirmed information security and privacy incidents and breaches to the CMS Incident Response Team (IRT) *via the CMS Help Desk (410) 786-2580 or CMS IT Service Desk (cms_it_service_desk@cms.hhs.gov)*, COR, CO, CMS SOP (or his or her designee), and other stakeholders, including breaches involving PII, in any medium or form, including paper, oral, or electronic, as soon as possible and without unreasonable delay, no later than **one (1) hour**, and consistent with the applicable CMS and HHS policy and procedures, NIST standards and guidelines, as well as US-CERT notification guidelines. The types of information required in an incident report must include at a minimum: company and point of contact information, contact information, impact

classifications/threat vector, and the type of information compromised. In addition, the Contractor must:

- Cooperate and exchange any information, as determined by the Agency, necessary to effectively manage or mitigate a suspected or confirmed breach;
 - Not include any sensitive information in the subject or body of any reporting e-mail; and
 - Encrypt sensitive information in attachments to email, media, etc.
- iv. Comply with OMB M-17-12, *Preparing for and Responding to a Breach of Personally Identifiable Information*, and HHS/CMS privacy breach response policies when handling PII breaches.
- v. Provide full access and cooperate on all activities as determined by the Government to ensure an effective incident response, including providing all requested images, log files, and event information to facilitate rapid resolution of sensitive information incidents. This may involve disconnecting the system processing, storing, or transmitting the sensitive information from the Internet or other networks or applying additional security controls. This may also involve physical access to contractor facilities during a breach/incident investigation.

5. Position Sensitivity Designations

All Contractor (and/or any subcontractor) employees must obtain a background investigation commensurate with their position sensitivity designation that complies with Parts 1400 and 731 of Title 5, Code of Federal Regulations (CFR). The following position sensitivity designation levels apply to this solicitation/contract:

6. Homeland Security Presidential Directive (HSPD)-12

The Contractor (and/or any subcontractor) and its employees must comply with Homeland Security Presidential Directive (HSPD)-12, *Policy for a Common Identification Standard for Federal Employees and Contractors*; OMB M-05-24; OMB M-19-17; FIPS 201, *Personal Identity Verification (PIV) of Federal Employees and Contractors*; HHS HSPD-12 policy; and *Executive Order 13467, Part 1 §1.2*.

7. Roster

The Contractor (and/or any subcontractor) must submit a roster by name, position, e-mail address, phone number and responsibility, of all staff working under this acquisition where the Contractor will develop, have the ability to access, or host and/or maintain a government information system(s). The roster must be submitted to the COR and/or CO within a timeframe to be determined by CMS of the effective date of this contract. Any revisions to the roster as a result of staffing changes must be submitted within a timeframe to be determined by CMS of the change. The COR will notify the Contractor of the appropriate level of investigation required for each staff member.

If the employee is filling a new position, the Contractor must provide a position description and the Government will determine the appropriate suitability level.

8. Contract Initiation and Expiration

- a. **General Security Requirements.** The Contractor (and/or any subcontractor) must comply with information security and privacy requirements, Enterprise Performance Life Cycle (EPLC) processes, HHS Enterprise Architecture requirements to ensure information is appropriately protected from initiation to expiration of the contract. All information systems development or enhancement tasks supported by the contractor must follow the HHS EPLC framework and methodology or the CMS SDLC, as amended and in accordance with the HHS Contract Closeout Guide (2012).
- b. **System Documentation.** Contractors (and/or any subcontractors) must follow and adhere to HHS System Development Life Cycle requirements, at a minimum, for system development and provide system documentation at designated intervals (specifically, at the expiration of the contract) within the EPLC and CMS SDLC that require artifact review and approval.
- c. **Sanitization of Government Files and Information.** As part of contract closeout and at expiration of the contract, the Contractor (and/or any subcontractor) must provide all required documentation in accordance with the CMS SDLC, as Amended to the CO and/or COR to certify that, at the government's direction, all electronic and paper records are appropriately disposed of and all devices and media are sanitized in accordance with NIST SP 800-88, *Guidelines for Media Sanitization*.
- d. **Notification.** The Contractor (and/or any subcontractor) must notify the CO and/or COR and system ISSO within as soon as possible or as determined by CMS before an employee stops working under this contract.
- e. **Contractor Responsibilities upon Physical Completion of the Contract.** The contractor (and/or any subcontractors) must return all government information and IT resources (i.e., government information in non-government-owned systems, media, and backup systems) acquired during the term of this contract to the CO and/or COR. Additionally, the Contractor must provide a certification that all government information has been properly sanitized and purged from Contractor-owned systems, including backup systems and media used during contract performance, in accordance with HHS and/or CMS policies.
- f. The Contractor (and/or any subcontractor) must perform and document the actions identified the COR when an employee terminates work under this contract within 30 calendar days of the employee's exit from the contract. All documentation must be available to the CO and/or COR upon request.

9. Records Management and Retention

- a. The Contractor (and/or any subcontractor) must maintain all information in accordance with Executive Order 13556 – Controlled Unclassified Information, National Archives and Records Administration (NARA) records retention policies and schedules and *HHS Policy for Records Management* and CMS policies and must not dispose of any records unless authorized by HHS/CMS.
- b. In the event that a contractor (and/or any subcontractor) accidentally disposes of or destroys a record without proper authorization, he/she must document and report the incident in accordance with HHS/CMS policies.

High Value Asset (HVA)

If a system is identified as HVA, the contractor must comply with the HHS Policy for the High Value Asset (HVA) Program and the DHS HVA Control Overlay in addition to the above requirements